

BALAJI SANGANA

balajisangana731@gmail.com | +91 90322 14319 | [linkedin.com/in/balaji-sangana](https://www.linkedin.com/in/balaji-sangana) | github.com/balaji-sangana

PROFESSIONAL SUMMARY

Security-aware Full Stack Web Developer and active Penetration Tester currently working part-time at BeeS Software Solutions, conducting VAPT engagements on production educational ERP and cloud platforms. Shipped a production multi-role web application from zero — architecting the full stack, building a REST API backend, implementing RBAC, and enforcing OWASP Top 10 controls end-to-end. Independently identified and responsibly disclosed critical vulnerabilities in a Government of India web portal, receiving official acknowledgment from NCIIPC. Proficient in Burp Suite, SQLmap, Nmap, Metasploit, OWASP ZAP, and custom Python offensive tooling. The rare combination of developer depth and attacker mindset enables building applications that are inherently harder to compromise — and breaking those that are not.

CORE COMPETENCIES & TECHNICAL SKILLS

Frontend Development: JavaScript (ES6+), HTML5, CSS3, React (fundamentals), Bootstrap, Responsive Design, Browser-based interpreter design

Backend Development: PHP (OOP), Python, Flask, Node.js (fundamentals), REST API Design, Session Management, RBAC Authentication

Databases: MySQL, MongoDB, Schema Design, SQL Queries, phpMyAdmin, Parameterized Queries

Dev Tools & Deployment: Git, GitHub, VS Code, Apache, Hostinger, .htaccess, Postman, Agile/Scrum

Penetration Testing: Full-scope black-box & gray-box web application pentesting, manual exploitation, PoC development

Exploitation & Proxy Tools: Burp Suite (intercept, repeater, intruder), browser DevTools, custom Python payloads, CVSS 3.1 scoring

Vulnerability Classes: SQL Injection, XSS, Authentication Bypass, IDOR, Broken Access Control, Sensitive Data Exposure, DoS

Security Automation & Tools: Burp Suite, SQLmap, Nmap, Metasploit, OWASP ZAP, custom Python payloads, CVSS 3.1 scoring, OSINT/recon CLI

Standards & Frameworks: OWASP Top 10, Coordinated Responsible Disclosure, NCIIPC Disclosure Process, Secure Coding Practices

KEY ACHIEVEMENT

NCIIPC-Acknowledged Security Researcher — Independently discovered and responsibly disclosed critical vulnerabilities (authentication bypass, sensitive data exposure, misconfigured access controls) in a live Government of India web infrastructure portal. Received official acknowledgment from the National Critical Information Infrastructure Protection Centre (NCIIPC), the Government of India's nodal agency for critical infrastructure protection.

PROJECTS

Government Web Infrastructure Security Assessment | *Burp Suite · Python · Manual Exploitation*
[PENTESTING] [DISCLOSED]

- **Executed a full-scope black-box web application penetration test** against a Government of India web portal — identified authentication bypass, sensitive data exposure, and misconfigured access controls through systematic manual testing.
- **Confirmed exploitability via Burp Suite and custom Python payloads**, producing full Proof of Concept (PoC) documentation, CVSS 3.1 severity ratings, and step-by-step remediation guidance for each vulnerability.
- Followed coordinated disclosure standards: maintained confidentiality during remediation window, submitted structured vulnerability reports to NCIIPC, and verified patches post-fix — receiving official Government of India acknowledgment.

College ERP Management System — Full Stack Greenfield Build | *PHP · MySQL · JavaScript · HTML5/CSS3 · Live on Hostinger* **[WEB DEV] [SECURITY]**

- **Owned the complete application lifecycle from zero:** chose the stack, architected the database schema, built a REST-style PHP/MySQL backend, developed a responsive JavaScript/CSS3 frontend, and deployed to Hostinger — covering 8+ modules including departments, timetable, attendance, leave, events, and announcements.
- **Implemented Role-Based Access Control (RBAC)** for Admin, HOD, and Staff roles with server-side session authentication — role-specific dashboards, scoped data access, and real-time notification delivery across user roles.
- **Hardened the application end-to-end using OWASP Top 10 controls:** parameterized queries (SQL Injection prevention), output encoding (XSS prevention), .htaccess directory protection, HTTPS enforcement, and password_hash() for credential storage.
- Implemented complex multi-step workflows: leave approval chains, class exchange requests, event coordinator assignment, participant registration, and scoped announcements at college/department/year granularity.

DVAT – Dynamic Vulnerability Assessment Tool | *Python · HTTP Automation · API Security Testing* [PENTESTING] [TOOLING]

- Built a Python offensive security tool to automate stress testing of web application and API defenses against high-rate traffic and DoS patterns — validates rate limiting, WAF rules, and input validation controls via automated HTTP request simulation.
- Demonstrates offensive tool engineering: requirement scoping, HTTP automation, payload crafting, test case design, and evidence-based result reporting — directly applicable to both pentest engagements and security platform development.

Domain Enumeration & Reconnaissance Tool | *Python · DNS/WHOIS APIs · OSINT* [PENTESTING]

- Developed a Python CLI tool for automated offensive reconnaissance: subdomain enumeration, DNS record analysis, WHOIS lookups, and infrastructure mapping — implements the full pre-engagement recon phase of a web application pentest.
- Showcases API consumption, structured data parsing, and building developer-facing security tooling — skills that bridge offensive research and software engineering.

TOBE LAN – Custom Programming Language & Browser-Based Interpreter | *JavaScript · Language Design · Open Source* · *Live: tobelan.github.io/tobelan* [WEB DEV] [OPEN SOURCE]

- **Designed and built a complete programming language (TOBE LAN) from scratch** — including language specification (v1.0), grammar rules, data types, indentation-based syntax, and a full JavaScript-based interpreter that executes TOBE programs entirely in the browser without any backend.
- **Engineered a browser-based interactive IDE/playground:** in-browser code editor, instant script execution via the custom JS interpreter, .tb file downloads, clipboard integration, built-in documentation panel, and sample programs — all as a fully client-side web application.
- Demonstrates advanced JavaScript skills beyond typical DOM manipulation — building a runtime execution engine, token parsing, and interpreter logic entirely in JS; deployed live as an open-source project on GitHub Pages.
- Language designed with a security researcher's mindset: controlled execution environment, sandboxed client-side runtime, no server-side attack surface — highlights how language/tool design intersects with security architecture.

Appointment Management System | *Python · Flask · MongoDB · HTML5/CSS3/Bootstrap · REST API* [WEB DEV] [FULL STACK]

- **Built a production-ready full-stack appointment scheduling platform using Python/Flask and MongoDB** — covering end-to-end features: user authentication (login/signup), appointment booking with date & time picker, personal dashboard for upcoming and past appointments, and an admin panel for user and appointment management.
- **Designed and implemented a Flask REST API backend** with MongoDB as the data layer — enabling scalable, schema-flexible storage for appointments and user data, and exposing clean API endpoints for potential integration with third-party services.
- **Implemented secure user authentication** — session management, login/signup flows, and role-separated admin panel access, applying the same secure coding practices (secret key configuration, environment-variable secrets via .env) used in production deployment environments.
- Demonstrates Python backend versatility beyond PHP: Flask routing, MongoDB query design, virtual environment management, and dependency isolation via requirements.txt — ready for containerized or cloud deployment.

WORK EXPERIENCE

Security Researcher / Penetration Tester · BeeS Software Solutions Pvt. Ltd. (Part-Time, Remote)
Apr 2026 – Present

- **Conducting full-scope web application penetration testing (VAPT)** for production educational ERP platforms, student management systems, examination portals, and institutional cloud applications — identifying and responsibly disclosing vulnerabilities in live enterprise environments.
- **Identified and documented critical-severity vulnerabilities including SQL Injection (SQLi), XSS, CSRF, Authentication Bypass, IDOR, privilege escalation, and business logic flaws** — each with full Proof-of-Concept exploits, CVSS scores, impact analysis, and remediation recommendations aligned with OWASP Top 10 and CWE standards.
- Executing black-box and source-level security assessments using Burp Suite, SQLmap, Nmap, Metasploit, OWASP ZAP, and custom scripts — analyzing HTTP/HTTPS traffic, REST APIs, session management, authentication workflows, and access control mechanisms to surface misconfigurations and insecure coding patterns.
- Collaborating directly with developers, QA teams, and stakeholders to reproduce confirmed findings, validate applied patches, and perform remediation verification testing — closing the loop between discovery and fix.
- Secured cloud-hosted ERP applications by reviewing input validation controls, database interaction security, and cloud configuration hardening — helping reduce organizational security risk across multiple production environments.

Python Programming Intern · SkillDzire (APSCHE Collaboration) *Dec 2025 – Mar 2026*

- Completed 3-month APSCHE-recognized Python internship; built proficiency in scripting, application logic, and automation workflows applied to both web application development and security tooling. Certificate ID: 35oibf53i2

Python Full Stack Intern · CodeTantra Tech Solutions Pvt. Ltd. *May 2025 – Jun 2025*

- Achieved 98% consolidated score (49/50) in a 40-day Python Full Stack program — perfect continuous assessment (15/15), near-perfect final evaluation (34/35). Gained hands-on full-stack development experience across frontend, backend, and database layers. Certificate: CT007320250830PYFS

Cybersecurity Intern · AND Intern (Virtual) *Jun 2024 – Aug 2024*

- Performed structured web application security testing on enterprise ASP.NET/IIS targets — executed REST API penetration testing covering authentication, authorization, session management, and input validation attack vectors.
- Collaborated with development teams to reproduce confirmed vulnerabilities, advise on OWASP Top 10 secure coding practices, and verify remediation — bridging the gap between offensive security findings and developer implementation.

Cybersecurity Intern · Palo Alto Networks (Virtual) *Apr 2024 – Jun 2024*

- Completed structured training on network security, application architecture, and threat detection — built deep understanding of how modern web infrastructure is designed, deployed, and exploited across both attacker and defender perspectives.

EDUCATION

B.Tech – Computer Science Engineering (Internet of Things) *Sep 2022 – May 2026*
Parvatha Reddy Babul Reddy Visvodaya Institute of Technology & Science, Nellore | CGPA: 6.85

Board of Intermediate Education (MPC) *2020 – 2022*
Narayana Junior College, Dhanalakshmiipuram, Nellore | 78.5%

Board of Secondary Education (SSC) *2019 – 2020*
Narayana High School, Vinjamur, Nellore | 95%

CERTIFICATIONS & SECURITY RECOGNITION

Ethical Hacking Essentials — EC-Council Learning | Certificate verifiable online

NCIIPC Acknowledgment — Government of India | Responsible Disclosure, Critical Infrastructure Vulnerabilities | 2024